

Azure Zero-Trust Terraform Cheat Sheet

8 production-ready patterns for NSGs, Private
Endpoints, Managed Identities & Forced Tunneling

1 — NSG DEFAULT-DENY BASELINE

● Deny-All Outbound (ISO 27001 baseline)

```
resource "azurerm_network_security_rule" "deny_all_out" {
  name                = "DenyAllOutbound"
  priority            = 4096
  direction           = "Outbound"
  access              = "Deny"
  protocol            = "*"
  source_port_range   = "*"
  destination_port_range = "*"
  source_address_prefix = "*"
  destination_address_prefix = "*"
  resource_group_name = var.resource_group_name
  network_security_group_name = azurerm_network_security_group.spoke.name
}
```

● Deny-All Inbound + Allow VNet Internal

```
# 4095 - allow internal VNet traffic
resource "azurerm_network_security_rule" "allow_vnet_in" {
  priority            = 4095
  direction           = "Inbound"
  access              = "Allow"
  protocol            = "*"
  source_address_prefix = "VirtualNetwork"
  destination_address_prefix = "VirtualNetwork"
  # ... (name, rg, nsg_name)
}

# 4096 - deny everything else
resource "azurerm_network_security_rule" "deny_all_in" {
  priority = 4096
  direction = "Inbound"
  access    = "Deny"
  # source/dest = "*"
}
```

Rule: Always set 4096 deny-all as the last rule. Never rely on Azure's implicit deny — make it explicit for audit evidence.

- Key Vault — full Private Link stack (works identically for Storage, ACR, SQL)

```
resource "azurerm_private_endpoint" "kv" {
  name                = "pe-kv-${var.environment}"
  location            = var.location
  resource_group_name = var.resource_group_name
  subnet_id          = azurerm_subnet.private_endpoints.id

  private_service_connection {
    name                = "psc-kv"
    private_connection_resource_id = azurerm_key_vault.main.id
    subresource_names   = ["vault"]      # "blob", "sqlServer", "registry"
    is_manual_connection = false
  }

  private_dns_zone_group {
    name                = "kv-dns-group"
    private_dns_zone_ids = [azurerm_private_dns_zone.kv.id]
  }
}

resource "azurerm_private_dns_zone" "kv" {
  name                = "privatelink.vaultcore.azure.net"
  resource_group_name = var.resource_group_name
}

resource "azurerm_private_dns_zone_virtual_network_link" "kv" {
  name                = "link-kv-${var.environment}"
  resource_group_name = var.resource_group_name
  private_dns_zone_name = azurerm_private_dns_zone.kv.name
  virtual_network_id   = azurerm_virtual_network.spoke.id
  registration_enabled = false
}
```

PRIVATE DNS ZONE NAMES — QUICK REFERENCE

Service	subresource_names	Private DNS Zone
Key Vault	["vault"]	privatelink.vaultcore.azure.net
Storage — Blob	["blob"]	privatelink.blob.core.windows.net
Storage — File	["file"]	privatelink.file.core.windows.net
Azure SQL	["sqlServer"]	privatelink.database.windows.net
Azure Container Registry	["registry"]	privatelink.azurecr.io
Azure OpenAI	["account"]	privatelink.openai.azure.com
AI Search	["searchService"]	privatelink.search.windows.net
App Service / Functions	["sites"]	privatelink.azurewebsites.net

● System-Assigned (simplest)

```
resource "azurerm_linux_function_app" "main" {
  # ...
  identity {
    type = "SystemAssigned"
  }
}

resource "azurerm_role_assignment" "fn_kv_reader" {
  scope           = azurerm_key_vault.main.id
  role_definition_name = "Key Vault Secrets User"
  principal_id    = azurerm_linux_function_app.main.identity[0].principal_id
}
```

● User-Assigned (reusable, recommended)

```
resource "azurerm_user_assigned_identity" "app" {
  name           = "id-app-${var.environment}"
  location       = var.location
  resource_group_name = var.resource_group_name
}

resource "azurerm_role_assignment" "app_blob_contrib" {
  scope           = azurerm_storage_account.main.id
  role_definition_name = "Storage Blob Data Contributor"
  principal_id    = azurerm_user_assigned_identity.app.principal_id
}

# Attach to any resource:
# identity { type = "UserAssigned"
#   identity_ids = [azurerm_user_assigned_identity.app.id] }
```

Role Principle: Always use the least-privileged built-in role. Key Vault Secrets User (read-only) beats Key Vault Contributor (control plane). Never assign Owner to a managed identity.

- Route table — default route + KMS / Azure AD bypass (prevents broken Windows VMs & auth failures)

```
resource "azurerm_route_table" "spoke" {
  name                       = "rt-spoke-${var.environment}"
  location                   = var.location
  resource_group_name        = var.resource_group_name
  disable_bgp_route_propagation = true
}

# Default route – send everything to the firewall
resource "azurerm_route" "default" {
  name                = "DefaultRoute"
  resource_group_name = var.resource_group_name
  route_table_name    = azurerm_route_table.spoke.name
  address_prefix      = "0.0.0.0/0"
  next_hop_type       = "VirtualAppliance"
  next_hop_in_ip_address = azurerm_firewall.main.ip_configuration[0].private_ip_address
}

# KMS bypass – without this, Windows VMs fail to activate
resource "azurerm_route" "kms" {
  name                = "KMSBypass"
  route_table_name    = azurerm_route_table.spoke.name
  address_prefix      = "168.63.129.16/32" # Azure platform IP
  next_hop_type       = "Internet"
}

# AzureAD bypass – prevents Managed Identity auth failures
resource "azurerm_route" "aad" {
  name                = "AzureADBypass"
  route_table_name    = azurerm_route_table.spoke.name
  address_prefix      = "AzureActiveDirectory"
  next_hop_type       = "Internet"
}
```

Why 168.63.129.16/32? This is Azure's internal platform IP used for KMS activation, health probes, and DNS. Routing it through a firewall drops these platform calls silently — Windows VMs will activate but show license errors hours later.

- Prevent "Resource was modified after deployment" pipeline failures

```
resource "azurerm_private_dns_zone_virtual_network_link" "kv" {
  # ... standard config ...

  lifecycle {
    ignore_changes = [
      tags,          # DINE policies inject tags after creation
      registration_enabled,
    ]
  }
}

# Same pattern for NSGs — DeployIfNotExists policies
# modify NSG rules or add diagnostic settings:
resource "azurerm_network_security_group" "spoke" {
  # ...

  lifecycle {
    ignore_changes = [security_rule, tags]
  }
}
```

When to use: Any resource in a tenant with Azure Policy (DINE or Modify effects). Without this, every `terraform plan` after policy remediation shows a diff — and applies break the policy-managed state.

- Automate the Portal click that blocks every AI RAG deployment

```
resource "azapi_update_resource" "approve_search_link" {
  type      = "Microsoft.Search/searchServices@2024-03-01-preview"
  resource_id = azurerm_search_service.main.id

  body = {
    properties = {
      sharedPrivateLinkResources = [
        {
          name = "pl-to-openai"
          properties = {
            groupId              = "openai_account"
            privateLinkResourceId = azurerm_cognitive_account.openai.id
            requestMessage        = "Approved by Terraform"
            status                 = "Approved"
          }
        }
      ]
    }
  }

  depends_on = [azurerm_search_service.main]
}

# Required provider block:
# terraform { required_providers {
#   azapi = { source = "Azure/azapi", version = "~> 1.0" } }}

```

Why AzAPI and not azurearm? The azurearm provider has no resource for Shared Private Link approval — it's missing from the SDK. `azapi_update_resource` patches the ARM API directly, eliminating the manual Portal approval step that breaks every automated AI RAG deployment.

- Zero public access, soft-delete, purge protection — ISO 27001 / NIS2 baseline

```
resource "azurerm_key_vault" "main" {
  name                = "kv-${var.project}-${var.environment}"
  location             = var.location
  resource_group_name = var.resource_group_name
  tenant_id           = data.azurerm_client_config.current.tenant_id
  sku_name             = "standard"

  enable_rbac_authorization = true # disable legacy access policies
  soft_delete_retention_days = 90
  purge_protection_enabled  = true # mandatory for KRITIS / NIS2
  public_network_access_enabled = false # Private Endpoint only

  network_acls {
    default_action = "Deny"
    bypass         = "AzureServices" # allow ARM to reach it for policy
    ip_rules       = []
  }
}
```

8 — NIS2 ART. 21 / ISO 27001 CONTROL → TERRAFORM RESOURCE MAP

Control Requirement	NIS2 Art. 21	ISO 27001	Terraform Resource(s)
Network segmentation	§21(2) (i)	A.8.22	azurerm_subnet + azurerm_network_security_group
Default-deny access control	§21(2) (i)	A.8.20	azurerm_network_security_rule priority 4096 Deny
Eliminate public exposure	§21(2) (h)	A.8.21	azurerm_private_endpoint + public_network_access_enabled = false
Least-privilege identity	§21(2) (i)	A.8.2	azurerm_user_assigned_identity + azurerm_role_assignment
Encrypt data in transit	§21(2) (h)	A.8.24	min_tls_version = "TLS1_2" on all storage/app resources
Secret management / key rotation	§21(2) (h)	A.8.24	azurerm_key_vault with purge_protection_enabled = true
Audit trail / immutable logging	§21(2) (f)	A.8.15	azurerm_monitor_diagnostic_setting → Log Analytics / Storage
Egress traffic filtering	§21(2) (i)	A.8.22	azurerm_firewall_policy_rule_collection_group (FQDN allow-list)

